

# Canevas de présentation sur DevSecOps

## 1. Introduction

### 1.1. Rappel de ce que c'est DevOps

- Définition
- Objectifs

### 1.2. Présentation de DevSecOps

- Définition
- Pourquoi DevSecOps
- Avantages
- Expliquer le principe de "Shift-left" et "Shift-right" de la sécurité

### 1.3. Objectifs de l'intégration sécurité dès le début du cycle dev

## 2. Présentation des modèles de sécurité

### 2.1. CIA — *Confidentialité, Intégrité, Disponibilité*

### 2.2. STRIDE — *Menaces de sécurité logiques*

### 3. Vue d'ensemble du pipeline DevSecOps

#### 3.1. Phase et Outils

| Phase   | Objectif sécurité                         | Outil recommandé            | Description outil                       |
|---------|-------------------------------------------|-----------------------------|-----------------------------------------|
| Plan    | Analyser les risques et exigences         | OWASP Threat Dragon         | Modélisation de menaces                 |
| Code    | Sécuriser le code source dès la rédaction | SonarQube                   | Analyse statique / détection de secrets |
| Build   | Sécuriser les dépendances                 | Snyk                        | Analyse des bibliothèques tierces       |
| Test    | Détecter les vulnérabilités dans l'appli  | OWASP ZAP                   | Analyse dynamique / SAST / DAST         |
| Release | Valider les artefacts                     | Trivy                       | Signature des binaires                  |
| Deploy  | Sécuriser l'infrastructure                | OPA                         | Analyse de configuration                |
| Operate | Protéger en production                    | Falco                       | Détection d'anomalies comportementales  |
| Monitor | Surveiller, alerter, réagir               | Grafana + Prometheus + Loki | Journalisation, SIEM                    |

### 3.2. STRIDE par phase + contrôles recommandés :

| Phase | STRIDE principal | Contrôles recommandés                |
|-------|------------------|--------------------------------------|
| Plan  | R, T             | Threat modeling, revue de politiques |

## 4. Présentation de l'outil – Démo théorique

Ex. Phase : Test

- **Outil: OWASP ZAP (Zed Attack Proxy)**
- **Rôle :** Scanner l'application pendant l'exécution pour trouver des failles (XSS, injection, etc.)

**STRIDE couverts :**

| Menace    | Cas simulé                         | Réaction de l'outil     |
|-----------|------------------------------------|-------------------------|
| Tampering | Injection de code JS dans un champ | Détection de faille XSS |

## 5. Démo pratique

- Exécution d'un pipeline CI/CD avec ZAP
- Présentation des résultats dans un rapport format HTML ou autres
- Blocage de la mise en production si faille critique

## 6. Recommandations

## 7. Conclusion

## 8. Annexes / Références